

Cross-Site Scripting Attacks Prevention is Better than Cure

Today, the Internet is full of crooks who could relieve you of your identity, your accounts and other valuable information, using malicious attacks such as cross-site scripting (XSS). But if you are aware of the various XSS methods used, and the open source tools that help you detect them, you could prevent such attacks.



With the growth of the Internet, there has been an increase in the number and type of malicious online attacks. Remote code execution, SQL injection, cross-site scripting (XSS) and cross-site request forgery (CSRF) are some of the well known attacks, apart from several others. One vulnerability that is often exploited is cross-site scripting (XSS), which this article will focus on.

XSS vulnerabilities have been reported and exploited for more than a couple of decades. These can tamper data, as well as steal sensitive data or user sessions. The consequences may be severe, depending on the sensitivity of the data and the capabilities of the attacker.

Cross-site scripting (XSS) is a vulnerability typically found in Web applications. An attack on this class of vulnerabilities occurs when an attacker injects malicious code into a Web application in an attempt to gain access to unauthorised information. In such situations, the victims are unaware that

information is being transferred from a site that they trust to another site controlled by the attackers. The attackers run their own client-side scripts (especially JavaScript) into Web pages. In a typical XSS attack, attackers inject their malicious JavaScript code into the legitimate website. When a user visits the specially-crafted link, the malicious JavaScript code will be executed. A successfully exploited XSS vulnerability will allow attackers to carry out phishing attacks, steal accounts and even inject worms. One of the key concepts of XSS is that the victim is the user, not the application.

Types of XSS

Reflected or non-persistent XSS: Reflected or non-persistent XSS is when the user input is accepted without any validation. In such cases, the injected code is sent as part of the request and shown in the response. Common locations for reflected XSS are in error messages or search results. Reflected attacks require